

PARTE I — O CASO

1.1 A empresa

Vale Norte Alimentos S.A. Indústria de massas e biscoitos, capital fechado, sede e planta em Ponta Grossa (PR), dois centros de distribuição (Curitiba e Londrina).

Dado	Valor
Funcionários	380 (312 na produção, 68 administrativos)
Faturamento anual	R\$ 240 milhões
Margem operacional	8%
Clientes	1.240 pessoas jurídicas (redes de supermercado, atacadistas)
Equipe de TI	6 pessoas — 1 coordenador, 2 infra, 2 suporte, 1 desenvolvedor
Profissionais dedicados à segurança	zero
Orçamento anual de TI	R\$ 1,4 milhão (0,58% do faturamento)

Ambiente tecnológico:

- ERP TOTVS Protheus (financeiro, fiscal, estoque, folha) em servidor Windows on-premises
- MES próprio (Java + PostgreSQL) controlando as três linhas de produção — apontamento, rastreabilidade de lote, receitas
- Active Directory com 412 contas
- VPN SSL para acesso remoto (administrativo, fornecedores e diretoria)
- Backup: rotina noturna do ERP para um NAS Synology **na mesma rede**, mais fita LTO levada mensalmente para o cofre do escritório contábil, no mesmo prédio
- E-mail: Microsoft 365, licenças Business Standard
- Firewall perimetral de borda, antivírus corporativo gratuito nas estações
- Sem SIEM, sem EDR, sem centralização de logs

Contexto de negócio no momento do incidente: a empresa acabara de fechar contrato de fornecimento com uma rede de supermercados que representa 22% do faturamento projetado, com **multa contratual de R\$ 90 mil por dia de atraso na entrega**.

1.2 O que a Vale Norte tinha a perder

Antes do incidente, a diretoria nunca havia feito esta lista. Ela foi montada **depois**, pela consultoria contratada para a resposta:

Item	Onde ficava
Base de 1.240 clientes PJ com condições comerciais e margens negociadas	ERP
Dados pessoais de 380 funcionários (CPF, RG, endereço, dados bancários, exames admissionais)	ERP + armário do RH
Fichas de admissão e atestados médicos assinados	Armário de aço no RH, sem chave desde 2022
Receitas e parâmetros de processo das 14 SKUs	MES + planilhas na rede
Código-fonte do MES	Servidor GitLab interno, sem cópia externa
Certificado digital A1 e-CNPJ	Instalado em três máquinas, senha anotada em post-it na mesa do fiscal
Contratos de fornecimento assinados	Arquivo físico + PDFs em pasta de rede
Conhecimento de operação das linhas	Na cabeça de dois operadores com 20 anos de casa
Sistema de emissão de NF-e	Serviço integrado ao ERP
Servidores, switches, nobreak, câmeras	Sala técnica no térreo, porta com chave guardada em gaveta destrancada
Reputação junto a clientes e à rede recém-contratada	—

1.3 Linha do tempo do incidente

Antecedentes — março de 2019

A Vale Norte contrata a **Sintec Automação**, integradora de São Paulo, para conectar o MES às balanças da linha 2. O técnico precisa de acesso remoto. A TI cria, às pressas, a conta de domínio `svc_sintec` com senha `Sintec@2019`, ingressa a conta no grupo VPN e — para evitar chamados de "senha expirada" durante o projeto — marca a opção **"a senha nunca expira"**.

O projeto termina em setembro de 2019. **A conta nunca é desativada.** Ninguém sabe que ela existe: a Sintec não é mais fornecedora desde 2021.

Novembro de 2023

Um fórum de vazamentos publica um *combolist* com 1,4 bilhão de pares usuário/senha agregados de vazamentos anteriores. Entre eles, o e-mail pessoal do técnico da Sintec e a senha `Sintec@2019`, que ele reutilizava em todos os lugares.

Dia -14 (segunda-feira)

Um **corretor de acesso inicial** (*initial access broker*) roda um script de *credential stuffing* contra o portal VPN da Vale Norte, encontrado por varredura de faixas de IP brasileiras na porta 443. A combinação `svc_sintec` / `Sintec@2019` autentica com sucesso na primeira tentativa.

Não há segundo fator. Não há alerta. O firewall registra a conexão como legítima — porque, formalmente, ela é.

O corretor valida o acesso, mapeia superficialmente a rede e anuncia em fórum: *"BR, food manufacturing, ~\$45M revenue, DA path likely, VPN access, \$1.800"*. Um afiliado de um grupo de **ransomware como serviço (RaaS)** compra o acesso quatro dias depois.

Dia -10 a Dia -3

O afiliado opera com calma, sempre entre 14h e 18h — horário comercial, para se confundir com o tráfego normal:

- Enumera o Active Directory com ferramentas nativas do Windows. Nenhum antivírus reage: `net`, `nltest` e `wmic` são binários legítimos do sistema (*living off the land*).
- Descobre o servidor de arquivos `SRV-FS01`, com **Windows Server 2012 R2 sem atualizações desde 2021** e a vulnerabilidade de escalonamento local **CVE-2021-1675 (PrintNightmare)** exposta.

- Explora a falha, obtém SYSTEM na máquina e extrai da memória as credenciais em cache. Entre elas, a do usuário `carlos.menezes`, do suporte — que é membro do grupo **Domain Admins**, porque em 2020 "era mais rápido assim" para instalar impressoras.
- Com privilégio de administrador de domínio, acessa tudo.

Dia -2 (quinta-feira, 15h)

Uma funcionária do financeiro recebe uma ligação: *"Aqui é o Rafael, da equipe de TI, estamos migrando o certificado digital. Você consegue confirmar a senha do e-CNPJ pra eu não travar a emissão de nota amanhã?"* Ela confirma. O número exibido era um DDD 42, local.

O atacante já tinha acesso administrativo — não precisava da senha. Ele queria **saber se conseguiria**. Precisava medir a maturidade humana da empresa antes de decidir o valor do resgate.

Dia -2 (quinta-feira, 22h) a Dia -1

Exfiltração de **42 GB** usando `Rclone` para um provedor de armazenamento em nuvem, em blocos de 500 MB com limite de banda configurado para não saturar o link. O tráfego sai pela porta 443, cifrado, indistinguível de um upload comum. Saem:

- backup completo do banco do ERP
- pasta `\\SRV-FS01\RH$` inteira
- repositório do MES
- pasta de contratos digitalizados

Dia 0 — sexta-feira, 23h41

O afiliado executa o *payload* via GPO, atingindo simultaneamente 214 estações e 9 servidores. A rotina do ransomware, antes de cifrar:

1. Encerra serviços de banco de dados e antivírus
2. Apaga as *shadow copies* do Windows
3. **Localiza e cifra o NAS Synology**, que estava no domínio, com uma pasta compartilhada mapeada como unidade `Z:` — o backup morre junto com o original
4. Cifra arquivos e deixa em cada diretório o arquivo `RESTORE-FILES.txt`

Às 23h58, o MES cai. A linha 3, que operava no turno da noite, para com massa em processo nas extrusoras. A perda de matéria-prima em processo: R\$ 47 mil.

Dia 1 — sábado

O coordenador de TI chega às 6h20. Encontra a tela de resgate. Desliga tudo — inclusive servidores ligados, o que **destrói evidência volátil em memória** que teria ajudado a perícia depois.

A negociação exigida no bilhete: **8 BTC**, aproximadamente **R\$ 2,4 milhões**, com prazo de 72 horas antes da publicação dos dados no site de vazamento do grupo. Prova de vida: três arquivos decifrados gratuitamente e uma captura de tela da pasta do RH.

A fita LTO mais recente é de **31 dias antes**. Ela restaura o ERP até um ponto útil — mas sem 31 dias de movimentação fiscal, financeira e de estoque. O MES não estava na rotina de fita. **Nunca esteve**. Ninguém havia testado uma restauração completa desde 2021.

Dia 1 a Dia 3

Reunião de crise: diretor-presidente, diretor financeiro, coordenador de TI, advogado externo, consultoria de resposta a incidentes contratada em regime de emergência (R\$ 180 mil).

Decisão: **não pagar**. Restaurar da fita, reconstruir os 31 dias a partir de documentos fiscais, e-mails e planilhas paralelas, reescrever o MES a partir de uma cópia local no notebook do desenvolvedor (14 dias desatualizada).

Linhas paradas: 62 horas. Retomada parcial na terça-feira, plena apenas no décimo primeiro dia.

Dia 9

O grupo publica 42 GB no site de vazamento. Dados de 380 funcionários e a tabela de margens por cliente ficam públicos. Dois clientes descobrem que pagavam mais caro que concorrentes do mesmo porte.

A empresa comunica a ANPD e os titulares no **dia 12** — sete dias após ter certeza da exfiltração.

Dia 30 — a auditoria interna

O comitê pergunta quem havia desabilitado a tarefa agendada que copiava o backup do NAS para a fita semanalmente. O log do servidor mostra a alteração feita em 14/02/2023 pela conta **administrador**.

Essa conta era usada por **quatro pessoas diferentes** da equipe de TI, com a senha compartilhada num arquivo do Excel na pasta do setor.

Ninguém pôde ser responsabilizado. E ninguém pôde se defender.

1.4 O custo real

Item	Valor
Margem perdida em 62h de parada	R\$ 806.000
Matéria-prima em processo descartada	R\$ 47.000
Multa contratual (2 dias de atraso na rede nova)	R\$ 180.000
Consultoria de resposta a incidentes	R\$ 180.000
Horas extras de TI, financeiro e fiscal na reconstrução	R\$ 96.000
Reescrita e revalidação do MES	R\$ 340.000
Aquisição emergencial de licenças e equipamentos	R\$ 210.000
Assessoria jurídica e comunicação de crise	R\$ 130.000
Provisão para exposição LGPD e ações trabalhistas	R\$ 400.000
Perda do contrato com a nova rede (rescindido no 4º mês)	R\$ 2.100.000 (receita anual projetada)
Total direto no exercício	≈ R\$ 2,39 milhões

O resgate pedido era **R\$ 2,4 milhões**.

PARTE II — EXTRAINDO OS CONCEITOS DO CASO

2.1 Ativos de informação

Ativo de informação é qualquer elemento que tenha valor para a organização e que sustente, armazene, processe ou transmita informação. Se a perda dele dói, é ativo.

Os tipos, identificados no caso

Tipo	Definição	Onde aparece na Vale Norte
Informação	O dado em si, independente do meio	Base de clientes com margens; dados pessoais dos 380 funcionários; receitas das 14 SKUs
Software	Aplicações, sistemas, código	ERP Protheus; MES próprio; código-fonte no GitLab
Físico / Hardware	Equipamentos e infraestrutura	Servidores; NAS; fita LTO; nobreak; sala técnica; as extrusoras da linha 3
Serviços	Funções entregues, próprias ou de terceiros	Emissão de NF-e; VPN; Microsoft 365; energia elétrica; link de internet
Pessoas	Competência, experiência e as credenciais que carregam	Os dois operadores com 20 anos de casa; a funcionária do financeiro que atendeu a ligação; o desenvolvedor cujo notebook salvou o MES
Documentos em papel	Registros físicos	Fichas de admissão e atestados no armário sem chave; contratos assinados

Tipo	Definição	Onde aparece na Vale Norte
Intangíveis	Reputação, marca, confiança, conformidade	Relação com a rede de supermercados; posição regulatória perante a ANPD

ATENÇÃO: Qual ativo, se perdido, levaria mais tempo para ser reconstruído — o servidor de banco de dados ou os dois operadores da linha 3? O servidor é reposto em 48 horas com cartão corporativo. Os operadores levam anos. Mesmo assim, só o servidor estava no orçamento de TI.

Regra que deve ficar: não existe proteção sem inventário. A Vale Norte não protegeu a conta `svc_sintec` porque **não sabia que ela existia**. Você não protege o que não sabe que tem.

2.2 A cadeia causal: vulnerabilidade → ameaça → ataque → incidente

Esta é a sequência que mais confunde. Ensine como uma equação, não como quatro definições soltas.

Vulnerabilidade

Fraqueza de um ativo ou controle que pode ser explorada. É uma condição *interna*, e ela existe mesmo que ninguém jamais a explore. É estática. É sua responsabilidade.

Vulnerabilidades da Vale Norte, por categoria:

Categoria	Vulnerabilidade concreta
Técnica	Windows Server 2012 R2 sem patch (CVE-2021-1675)
Técnica	VPN sem múltiplo fator de autenticação
Técnica	NAS de backup ingressado no mesmo domínio e com unidade mapeada
Técnica	Ausência de segmentação entre rede administrativa e rede industrial (OT)

Categoria	Vulnerabilidade concreta
Processual	Sem processo de <i>offboarding</i> de contas de fornecedor
Processual	Senha configurada para nunca expirar
Processual	Restauração de backup nunca testada desde 2021
Processual	Uso de conta administrativa compartilhada por quatro pessoas
Organizacional	Concessão de privilégio de Domain Admin a analista de suporte por conveniência
Organizacional	Ausência de inventário de ativos e de dono designado por ativo
Humana	Reutilização de senha pelo técnico terceiro
Humana	Ausência de treinamento contra engenharia social
Física	Armário do RH sem chave; chave da sala técnica em gaveta aberta; fita de backup no mesmo prédio

Note que **a maioria não é técnica**. Esse é o ponto pedagógico central da seção.

Ameaça

Causa potencial de um incidente indesejado. É *externa* à sua vontade. Você não elimina ameaças — elas existem independentemente de você. Você só reduz a exposição a elas.

Ameaças presentes no caso:

- **Intencionais externas:** o corretor de acesso inicial; o afiliado do grupo RaaS; o operador do RaaS que hospeda a infraestrutura
- **Intencionais internas:** um insider descontente — hipótese que a empresa **não conseguiu descartar nem confirmar** (volte a isso em 2.5)
- **Não intencionais:** a funcionária do financeiro que confirmou a senha ao telefone; o coordenador que desligou os servidores e destruiu evidências
- **Ambientais:** incêndio na sala técnica — que teria destruído servidores, NAS e a fita, todos no mesmo prédio

ATENÇÃO: a existência do grupo de ransomware é ameaça. A conta `svc_sintec` ativa é vulnerabilidade. A ameaça não é culpa da Vale Norte. A vulnerabilidade é.

Ataque

Tentativa de explorar uma vulnerabilidade. É a ameaça em movimento. Existe mesmo quando fracassa.

Ataques identificados, mapeados por técnica:

#	Ataque	Vulnerabilidade explorada	Resultado
1	<i>Credential stuffing</i> contra o portal VPN	Senha vazada e reutilizada + ausência de MFA	Sucesso
2	Reconhecimento de AD com binários nativos	Ausência de monitoramento de comportamento	Sucesso, não detectado
3	Exploração de PrintNightmare	Servidor sem patch	Escalonamento a SYSTEM
4	Extração de credenciais em memória	Cache de credencial privilegiada na máquina	Obtenção de Domain Admin
5	<i>Vishing</i> contra o financeiro	Ausência de treinamento e de procedimento de verificação	Sucesso
6	Exfiltração via Rclone sobre HTTPS	Ausência de DLP e de inspeção de saída	42 GB extraídos
7	Distribuição do ransomware via GPO	Controle total de domínio	223 hosts cifrados
8	Cifragem do backup	NAS no domínio	Recuperação inviabilizada

Um ataque não precisa ter sucesso para ser ataque. Se a Vale Norte tivesse MFA, o ataque nº 1 teria ocorrido e falhado — e teria gerado um alerta valioso.

Incidente de segurança

Evento ou série de eventos que compromete as operações do negócio ou ameaça a segurança da informação. É a consequência materializada.

Distinção que precisam gravar:

- **Evento:** uma autenticação VPN bem-sucedida às 3h da manhã. Observável, neutro.
- **Incidente:** a cifragem de 223 hosts e a exfiltração de 42 GB. Evento com consequência adversa confirmada.

Na Vale Norte, houve **eventos por 14 dias** antes do incidente ser percebido. Todos foram registrados em algum log. Nenhum foi lido, porque não havia quem lesse.

Tempo de permanência (dwell time): 14 dias. Esse número é a métrica que separa uma empresa que detecta de uma que descobre.

Risco

Efeito da incerteza sobre os objetivos. Operacionalmente, é a combinação entre a probabilidade de uma ameaça explorar uma vulnerabilidade e o impacto disso.

$RISCO = f(AMEAÇA \times VULNERABILIDADE \times IMPACTO \text{ SOBRE O ATIVO})$

Se qualquer termo é zero, o risco é zero. Aplicando ao caso:

- Ameaça de ransomware: alta (o grupo existe, é ativo, opera no Brasil)
- Vulnerabilidade: alta (VPN sem MFA, conta órfã, patch ausente)
- Impacto: severo (parada de produção, LGPD, contrato de 22% do faturamento)
- **Risco: crítico** — e estava assim havia quatro anos, sem ninguém ter escrito isso em lugar nenhum

Risco é **prospectivo**. Incidente é **retrospectivo**. Gestão de risco existe justamente para gastar dinheiro antes, e não depois.

Exercício de mensuração:

Variável	Definição	Vale Norte
SLE (<i>Single Loss Expectancy</i>)	Perda esperada por ocorrência	R\$ 2.390.000
ARO (<i>Annual Rate of Occurrence</i>)	Frequência anual estimada	0,25 (uma a cada 4 anos)
ALE (<i>Annualized Loss Expectancy</i>)	$SLE \times ARO$	R\$ 597.500/ano

O custo anual de MFA para 412 contas, EDR e backup imutável fica em torno de **R\$ 210 mil/ano**. Peça o cálculo do retorno. Depois pergunte por que, mesmo com essa conta fechando, a diretoria nunca aprovou o investimento. A resposta é o motivo pelo qual gestão de risco é uma disciplina de comunicação antes de ser uma disciplina técnica: **ninguém nunca apresentou o número**.

2.3 A Tríade CIA no caso

Confidencialidade

Garantia de que a informação é acessível apenas a quem está autorizado.

Violada em três momentos distintos:

1. Quando o atacante leu a base do ERP no dia -10 — violação já consumada, embora invisível
2. Quando 42 GB foram exfiltrados no dia -2
3. Quando os dados foram publicados no dia 9 — violação irreversível

Lição dura: confidencialidade é o único pilar da tríade que **não admite recuperação**. Disponibilidade volta com restore. Integridade volta com reconstrução. Dado vazado não volta.

Integridade

Garantia de exatidão e completude da informação e dos métodos de processamento.

Violada em duas dimensões:

- **Destrutiva:** a cifragem alterou todos os arquivos, tornando-os ilegíveis

- **Duvidosa — e mais grave:** durante 14 dias, um administrador de domínio não autorizado teve permissão de escrita em tudo. Depois do restore, a empresa **não tinha como provar** que preços, cadastros bancários de fornecedores e receitas de produção não haviam sido alterados antes da cifragem. Não havia *hashes*, não havia trilha de auditoria confiável, não havia linha de base.

A auditoria fiscal seguinte durou três meses. O passivo não foi o dado perdido, foi o **dado sob suspeita**.

Fixe o conceito: integridade sem mecanismo de verificação (hash, assinatura, log íntegro) não é integridade — é esperança.

Disponibilidade

Garantia de que a informação e os ativos estão acessíveis a quem tem direito, quando necessário.

- 62 horas de linhas paradas
- 11 dias até operação plena
- ERP com 31 dias de defasagem
- Emissão de NF-e interrompida — a empresa não conseguia **faturar o que produzia**

Aqui mora um insight : **o backup existia**. O que não existia era o *teste de restauração*. Backup não testado não é controle de disponibilidade; é documento de intenção.

E o golpe final: o NAS estava no domínio. Um controle de disponibilidade que compartilha a mesma superfície de ataque do ativo que protege **não é redundância, é duplicação do alvo**.

2.4 Autenticação e autorização

Separe com uma frase: **autenticação responde "quem é você?"; autorização responde "o que você pode fazer?"**.

Autenticação — o que falhou

A conta `svc_sintec` **autenticou corretamente**. Não houve burla criptográfica, não houve exploração de falha no protocolo. O sistema fez exatamente o que foi projetado para fazer: verificou que quem se apresentava conhecia o segredo.

O problema é que **o segredo deixou de ser secreto** e o sistema não tinha como saber disso.

Os três fatores, e o que a Vale Norte usava:

Fator	Exemplo	Vale Norte
Algo que você sabe	senha, PIN	Único fator usado
Algo que você tem	token, chave FIDO2, app autenticador	Ausente
Algo que você é	biometria	Ausente

Com um segundo fator, o ataque nº 1 falharia mesmo com a senha correta — porque o atacante tinha o *conhecimento*, mas não a *posse*.

Provoque: A senha *Sintec@2019* era "forte"? Tem maiúscula, minúscula, símbolo, número e 12 caracteres. Ela passaria em qualquer política corporativa. E foi inútil, porque força de senha protege contra adivinhação, não contra vazamento. Isso desmonta o mito mais persistente da segurança doméstica.

Autorização — o que falhou pior

Dois erros graves e independentes:

1. Violação do princípio do menor privilégio. *carlos.menezes* era analista de suporte e membro de Domain Admins. Sua função exigia instalar impressoras e reresetar senhas — nada que demandasse controle total do domínio. O privilégio excessivo transformou uma máquina comprometida em domínio comprometido.

2. Ausência de segregação de funções e de escopo. A conta de VPN de um fornecedor de automação de balanças tinha alcance para toda a rede. Deveria alcançar exatamente um host, numa janela de tempo aprovada, com sessão gravada.

Modelos que devem ser nomeados:

- **DAC** (discricionário) — o dono do recurso decide quem acessa. É o que a Vale Norte praticava por omissão: cada gestor liberava pasta para quem pedia
- **MAC** (obrigatório) — o sistema impõe rótulos de classificação; o usuário não pode delegar. Típico de ambientes militares
- **RBAC** (por papel) — permissão vinculada à função, não à pessoa. O que a Vale Norte deveria ter

- **ABAC** (por atributo) — decisão considera contexto: horário, dispositivo, localização, postura de segurança. Base do Zero Trust

Com RBAC bem implementado, a saída da Sintec do quadro de fornecedores em 2021 teria removido o papel e, com ele, o acesso — automaticamente.

2.5 Não repúdio — o conceito que o caso ensina melhor que qualquer aula

Não repúdio é a garantia de que alguém não pode negar de forma crível a autoria de uma ação, nem a participação em uma transação.

Volte ao Dia 30. A tarefa de cópia para fita foi desabilitada pela conta **administrador**. Quatro pessoas usavam essa conta com a mesma senha, guardada numa planilha.

Consequências que devem ser exploradas em debate:

1. **A empresa não pôde responsabilizar ninguém.** Se um dos quatro agiu de má-fé, saiu impune.
2. **Nenhum dos quatro pôde se inocentar.** Todos permaneceram sob suspeita. Dois pediram demissão nos seis meses seguintes.
3. **A perícia ficou cega.** Não foi possível determinar se a alteração foi ação interna deliberada, erro operacional ou já um movimento do atacante.
4. **A empresa não pôde acionar o seguro cyber com laudo conclusivo de causa,** o que atrasou a indenização.

A frase que deve sair da aula: não repúdio protege a organização **e** protege o indivíduo. Ele não é vigilância — é a única coisa que permite a um profissional honesto provar que não foi ele.

Requisitos técnicos para haver não repúdio:

Requisito	Por quê	Vale Norte
Identidade individual (uma conta por pessoa)	Sem isso, a ação não tem autor	Falhou
Autenticação forte	Senha compartilhada não prova identidade	Falhou

Requisito	Por quê	Vale Norte
Registro de auditoria completo	Sem log, não há evidência	Parcial
Log em servidor separado e imutável	Atacante com admin apaga o log local	Falhou
Sincronização de tempo (NTP)	Sem hora confiável, a cronologia não se sustenta	Falhou
Assinatura digital com chave privada sob controle exclusivo	Vincula ato e autor de forma criptográfica	Ausente

O último item merece destaque para a turma de Computação: **o certificado A1 com a senha em post-it destrói o não repúdio de todas as notas fiscais emitidas**. Juridicamente, a empresa assinou. Tecnicamente, qualquer um naquela sala poderia ter assinado. Assinatura digital só tem valor probatório se a chave privada estiver sob **controle exclusivo** do titular — e ali não estava.

Distinção fina que vale ponto na prova

Conceito	Pergunta que responde	Falha na Vale Norte
Autenticação	Quem é você?	Um fator só, senha vazada
Autorização	O que você pode fazer?	Privilegio excessivo
Accountability	O que você fez?	Logs locais, sem centralização
Não repúdio	Você pode negar que fez?	Conta compartilhada — sim, podia negar

Accountability é registrar. Não repúdio é registrar de modo que a negativa seja **insustentável**. Todo não repúdio pressupõe accountability; nem toda accountability alcança o não repúdio.

2.6 Risco residual

Risco residual é o que sobra depois de aplicados os controles. Ele nunca é zero. A questão não é eliminá-lo, é conhecê-lo e aceitá-lo formalmente, por escrito, com um nome e um cargo ao lado.

O risco residual que a Vale Norte tinha antes — sem saber

A empresa acreditava que tinha backup. Portanto, acreditava que o risco de ransomware estava tratado.

O risco residual **real** era: *backup na mesma rede, no mesmo domínio, nunca testado, sem cópia do MES, com fita mensal no mesmo prédio*. Ou seja, o controle existia no organograma e não existia na prática.

Ensine assim: risco residual mal calculado é pior que risco conhecido, porque produz falsa sensação de proteção — e a falsa sensação faz a empresa deixar de investir.

O risco residual depois do plano de tratamento

Mesmo com tudo da Parte IV implementado, permanece:

Risco residual	Por que persiste	Decisão
Exploração de <i>zero-day</i> na solução de VPN	Nenhum patch existe para falha desconhecida	Aceitar + mitigar com segmentação e detecção
Comprometimento de fornecedor com acesso legítimo	Terceiro é necessário à operação	Reduzir com acesso <i>just-in-time</i> e sessão gravada
Engenharia social bem-sucedida contra funcionário treinado	Treinamento reduz, não elimina	Aceitar + reduzir impacto com menor privilégio
Insider com privilégio legítimo	Alguém precisa ter as chaves	Reduzir com segregação de funções e dupla aprovação
Falha simultânea de site principal e réplica	Evento de baixíssima probabilidade	Transferir via seguro cyber

Fórmula conceitual:

RISCO INERENTE – EFICÁCIA DOS CONTROLES = RISCO RESIDUAL

RISCO RESIDUAL $\leq$ APETITE A RISCO → aceitar formalmente

RISCO RESIDUAL $>$ APETITE A RISCO → tratar mais, ou não operar

Quem assina a aceitação é o **dono do risco** — o diretor da área de negócio, não o coordenador de TI. Esse detalhe organizacional é o que separa governança de burocracia: a assinatura transfere a decisão para quem tem autoridade orçamentária para mudá-la.

PARTE III — PROBLEMAS IDENTIFICADOS

Consolidação por causa-raiz, com pilar afetado e criticidade.

#	Problema	Categoria	Pilar afetado	Criticidade
P01	Conta de fornecedor ativa 4 anos após o fim do contrato	Gestão de identidade	C, I, D	Crítica
P02	Ausência de MFA no acesso remoto	Autenticação	C, I, D	Crítica
P03	Backup na mesma rede e domínio do ativo protegido	Continuidade	D	Crítica
P04	Restauração nunca testada desde 2021	Continuidade	D	Crítica
P05	MES fora de qualquer rotina de backup	Continuidade	D	Crítica
P06	Conta administrativa compartilhada por 4 pessoas	Não repúdio	Accountability	Crítica
P07	Domain Admin concedido a analista de suporte	Autorização	C, I, D	Alta
P08	Servidor sem atualização desde 2021	Gestão de vulnerabilidades	C, I, D	Alta

#	Problema	Categoria	Pilar afetado	Criticidade
P09	Ausência de segmentação entre TI e rede industrial	Arquitetura	D	Alta
P10	Logs locais, sem centralização nem imutabilidade	Deteção / não repúdio	Accountability	Alta
P11	Ausência de monitoramento — 14 dias sem detecção	Deteção	C, I, D	Alta
P12	Senha de certificado digital em post-it	Não repúdio	I, não repúdio	Alta
P13	Ausência de inventário e classificação de ativos	Governança	Todos	Alta
P14	Nenhum treinamento de conscientização	Fator humano	C	Alta
P15	Sem plano de resposta a incidentes — evidência volátil destruída	Resposta	Todos	Alta
P16	Comunicação à ANPD no 12º dia	Conformidade	Legal	Alta
P17	Fita de backup armazenada no mesmo prédio	Continuidade / físico	D	Média

#	Problema	Categoria	Pilar afetado	Criticidade
P18	Armário do RH sem chave; chave da sala técnica em gaveta aberta	Segurança física	C	Média
P19	Ausência de controle de saída de dados (DLP)	Prevenção de vazamento	C	Média
P20	Sem gestão de risco de terceiros	Cadeia de suprimentos	C, I, D	Média

Causa-raiz única, se for preciso reduzir a uma frase: a Vale Norte tomava decisões de segurança por **conveniência operacional**, uma a uma, cada qual razoável isoladamente e catastrófica em conjunto. Ninguém jamais somou as decisões.

PARTE IV — PLANO DE TRATAMENTO

Estruturado por horizonte, com controle correspondente do Anexo A da ISO/IEC 27001:2022.

Horizonte 1 — 0 a 30 dias (contenção e higiene básica)

Ação	Problema	Controle A.27001	Custo estimado
Inventariar 100% das contas; desativar toda conta sem uso em 90 dias e toda conta de terceiro sem contrato ativo	P01	A.5.16, A.5.18	R\$ 0 (interno)
Implantar MFA obrigatório em VPN, e-mail e contas administrativas	P02	A.8.5	R\$ 34/usuário/ano
Eliminar contas administrativas compartilhadas; conta nominal + cofre de senhas	P06	A.5.17, A.8.2	R\$ 18 mil/ano
Revisar todos os membros de grupos privilegiados; remover privilégio permanente do suporte	P07	A.8.2	R\$ 0
Retirar backup do domínio; adotar repositório imutável com regra 3-2-1-1-0	P03, P17	A.8.13	R\$ 65 mil/ano
Incluir MES, GitLab e configurações de rede na rotina de backup	P05	A.8.13	R\$ 0

Ação	Problema	Controle A.27001	Custo estimado
Trocar a senha do certificado A1 e migrar para A3 em token	P12	A.8.24	R\$ 1,2 mil
Instalar fechadura no armário do RH; controle de chave da sala técnica	P18	A.7.2, A.7.4	R\$ 900

Horizonte 2 — 30 a 120 dias (visibilidade e resiliência)

Ação	Problema	Controle	Custo estimado
Teste de restauração completa documentado, com meta de RTO de 8h e RPO de 4h; repetição trimestral obrigatória	P04	A.5.30, A.8.13	R\$ 12 mil/ano
Implantar EDR em 100% dos servidores e estações	P08, P11	A.8.7, A.8.16	R\$ 92 mil/ano
Centralizar logs em servidor dedicado com retenção de 12 meses e escrita única; sincronizar NTP	P10	A.8.15	R\$ 40 mil/ano
Ciclo mensal de gestão de vulnerabilidades com janela de patch definida	P08	A.8.8	R\$ 22 mil/ano
Segmentar rede industrial da administrativa com	P09	A.8.20, A.8.22	R\$ 78 mil

Ação	Problema	Controle	Custo estimado
firewall interno e regras de negação padrão			
Elaborar e testar o plano de resposta a incidentes; simulado de mesa semestral	P15, P16	A.5.24 a A.5.28	R\$ 25 mil
Programa de conscientização com simulações de phishing e vishing trimestrais	P14	A.6.3	R\$ 16 mil/ano
Procedimento de notificação à ANPD com prazo interno de 48h	P16	A.5.34	R\$ 0

Horizonte 3 — 120 dias a 18 meses (governança)

Ação	Problema	Controle	Custo estimado
Inventário e classificação formal de ativos, com dono designado por ativo	P13	A.5.9, A.5.12	R\$ 30 mil
Processo de gestão de riscos conforme ISO 31000/27005, revisão semestral e matriz aprovada pela diretoria	P13	Cláusula 6	R\$ 45 mil
Implantar RBAC no ERP, MES e AD; revisão trimestral de acessos	P07	A.5.15, A.5.18	R\$ 60 mil

Ação	Problema	Controle	Custo estimado
Programa de segurança de fornecedores: cláusulas contratuais, questionário e acesso <i>just-in-time</i> com sessão gravada	P20, P01	A.5.19 a A.5.22	R\$ 55 mil
Implantar DLP para saída de dados e alerta de volume anômalo	P19	A.8.12	R\$ 70 mil/ano
BIA formal e BCP/DRP com sítio de contingência	P04, P05	A.5.29, A.5.30	R\$ 120 mil
Contratar seguro cyber com cobertura de interrupção e responsabilidade LGPD	Residual	A.5.7	R\$ 85 mil/ano
Estruturar cargo dedicado de segurança da informação com reporte à diretoria	Todos	A.5.2	R\$ 180 mil/ano

Investimento total no primeiro ano: ≈ R\$ 1,05 milhão. ALE do cenário antes do tratamento: R\$ 597,5 mil/ano. Custo real do incidente ocorrido: R\$ 2,39 milhões.

PARTE V — O INCIDENTE REAL: COLONIAL PIPELINE (2021)

A Vale Norte é ficção. O que segue não é.

5.1 Os fatos

A **Colonial Pipeline Company**, dos Estados Unidos, opera cerca de 8.850 km de dutos entre Houston e Nova York, transportando aproximadamente 45% de todo o combustível consumido na Costa Leste americana. Apesar dessa relevância, é uma empresa de porte comparável a uma indústria média: cerca de 900 funcionários.

Cronologia:

- **29 de abril de 2021** — invasores acessam a rede da Colonial usando a senha de uma **conta de VPN legada e inativa**, que continuava habilitada. A senha aparecia num vazamento anterior, indicando reutilização por um funcionário. **A conta não tinha autenticação multifator.**
- **6 de maio de 2021** — os atacantes exfiltram aproximadamente **100 GB de dados em cerca de duas horas.**
- **7 de maio de 2021, madrugada** — o grupo **DarkSide**, operando em modelo de ransomware como serviço, implanta o ransomware na rede de TI. Um funcionário encontra o bilhete de resgate por volta das 5h.
- **7 de maio** — a Colonial **desliga preventivamente toda a operação dos dutos.** O ataque atingiu a rede administrativa, não os sistemas de controle industrial; a parada foi decisão de contenção, agravada pela impossibilidade de faturar e medir o produto entregue.
- **7 de maio** — a empresa paga **75 bitcoins**, equivalentes a aproximadamente **US\$ 4,4 milhões**, poucas horas depois de descoberto o ataque. A ferramenta de decifragem entregue mostrou-se tão lenta que a Colonial recorreu aos próprios backups para a maior parte da recuperação.
- **9 de maio** — o governo americano declara estado de emergência regional em 17 estados e no Distrito de Columbia para permitir transporte rodoviário emergencial de combustível.
- **10 a 14 de maio** — compra por pânico esvazia postos: em alguns estados do Sudeste, mais de 70% dos postos ficam sem combustível. O preço médio da gasolina atinge o maior patamar em quase sete anos.
- **12 de maio** — operação dos dutos é reiniciada; a normalização da rede de distribuição leva vários dias.

- **7 de junho de 2021** — o Departamento de Justiça anuncia a recuperação de **63,7 bitcoins** do pagamento, então avaliados em cerca de **US\$ 2,3 milhões**, após rastrear a carteira e obter acesso à chave privada.
- **8 de junho de 2021** — o CEO **Joseph Blount** depõe perante o Senado americano. Ele confirma sob juramento que o acesso ocorreu por uma **VPN legada sem MFA**, que a decisão de pagar foi tomada por ele pessoalmente, e a descreve como a decisão mais difícil de sua carreira.

5.2 Por que este caso é o melhor material didático disponível

Porque o vetor inicial não envolveu genialidade técnica. Envolveu **uma conta que ninguém desativou e um segundo fator que ninguém habilitou** — exatamente os problemas P01 e P02 da Vale Norte.

E porque as consequências saíram completamente da escala do departamento de TI: filas em postos, decreto federal de emergência, depoimento no Senado. Um problema de gestão de identidade virou crise de abastecimento nacional.

5.3 Espelhamento entre os casos

Elemento	Colonial Pipeline (real)	Vale Norte (didático)
Vetor inicial	Conta VPN legada, senha vazada, sem MFA	Conta VPN de fornecedor, senha vazada, sem MFA
Vulnerabilidade central	Ausência de <i>offboarding</i> de credenciais	Idêntica
Ameaça	DarkSide (RaaS)	Afiliado de RaaS via corretor de acesso
Dupla extorsão	100 GB exfiltrados antes da cifragem	42 GB exfiltrados antes da cifragem
Pilar mais atingido	Disponibilidade (parada de 5 dias)	Disponibilidade (62h + 11 dias)
Decisão sobre o resgate	Pagou US\$ 4,4 mi; recuperou parcialmente e usou os próprios backups	Não pagou ; restaurou com defasagem de 31 dias
Impacto externo	Emergência em 17 estados	Perda de contrato de 22% do faturamento

Elemento	Colonial Pipeline (real)	Vale Norte (didático)
Desdobramento regulatório	Depoimento no Senado, nova diretriz da TSA para dutos	Comunicação à ANPD, exposição a sanção LGPD